

Plan de Seguridad — Goya Ledger PSC

Prestador de Servicios de Certificacion Goya Ledger

Campo	Valor
Version	1.0
Fecha	2026-08-13
Clasificacion	Confidencial
Aprobado por	[Nombre del Representante Legal]
Proximo revision	2027-08-13

1. Introduccion y alcance

1.1. Proposito

El presente Plan de Seguridad establece las politicas, controles tecnicos y procedimientos operacionales que Goya Ledger, en calidad de Prestador de Servicios de Certificacion (PSC), implementa para proteger la infraestructura de firma electronica, las claves criptograficas, los certificados digitales y la informacion de los suscriptores.

Este documento constituye un requisito exigido por el Decreto Supremo N.o 181 de 2002 del Ministerio de Economia, Fomento y Turismo, para efectos de la acreditacion ante la Subsecretaria de Economia y Empresas de Menor Tamano.

1.2. Alcance

El plan cubre la totalidad de los sistemas, procesos y personal involucrados en:

- La emision, renovacion, suspension y revocacion de certificados de firma electronica simple (FES) y firma electronica avanzada (FEA).
- La operacion de la Autoridad de Certificacion (CA), la Autoridad de Registro (RA) y la Autoridad de Sellado de Tiempo (TSA).
- La infraestructura de nodo blockchain basada en Rust/Actix-Web que sustenta la plataforma.
- Los servicios de validacion de certificados (OCSP, CRL).

- El almacenamiento y proteccion de claves criptograficas en HSM.
- Los registros de auditoria con cadena de hash.
- Los servicios de identidad descentralizada (DID).

1.3. Exclusiones

Quedan fuera del alcance los sistemas de terceros conectados mediante el modulo de bridge cross-chain (src/bridge/), los cuales se rigen por sus propias politicas de seguridad. No obstante, las interfaces de interconexion estan sujetas a los controles descritos en la seccion 7.

2. Marco normativo

2.1. Legislacion aplicable

Norma	Materia
Ley 19.799 (2002)	Sobre documentos electronicos, firma electronica y servicios de certificacion
Decreto Supremo N.o 24 (2019)	Modifica DS 181; actualiza requisitos tecnicos de PSC
Decreto Supremo N.o 181 (2002)	Reglamento de la Ley 19.799; requisitos de acreditacion de PSC
NCh-ISO 27001:2013	Sistema de gestion de seguridad de la informacion
NCh-ISO 27002:2022	Controles de seguridad de la informacion
ETSI EN 319 411-1/2	Politica y practicas de certificacion para CA cualificadas
ETSI EN 319 421	Requisitos para autoridades de sellado de tiempo
FIPS 140-2 Level 3	Requisitos de seguridad para modulos criptograficos
RFC 3647	Marco de politicas de certificacion y practicas de certificacion

2.2. Documentos internos de referencia

Documento	Ubicacion
Politica de Certificacion (CP)	docs/compliance/ — exportable via API
Declaracion de Practicas de Certificacion (CPS)	docs/compliance/ — exportable via API
Plan de Continuidad del Negocio	docs/compliance/BUSINESS-CONTINUITY-DR.md

Documento	Ubicacion
Plan de Respuesta a Incidentes	docs/compliance/INCIDENT-RESPONSE-PLAN.md
Marco de Cumplimiento	docs/compliance/COMPLIANCE-FRAMEWORK.md
Seguridad Fisica	docs/compliance/PHYSICAL-SECURITY.md
Modulo FIPS 140	docs/compliance/FIPS-140-MODULE.md
Hoja de ruta PSC	docs/compliance/PSC-CERTIFICATION-ROADMAP.md

3. Organizacion de la seguridad

3.1. Estructura organizacional

El PSC Goya Ledger mantiene la siguiente estructura de roles de seguridad, conforme al articulo 14 del DS 181:

Rol	Responsabilidad
Oficial de Seguridad (CISO)	Responsable de la aplicacion y supervision del presente plan. Reporta al Representante Legal.
Administrador de CA	Opera la Autoridad de Certificacion. Ejecuta ceremonias de claves. Custodio de credenciales HSM.
Oficial de Registro (RA)	Valida identidad de suscriptores. Verifica documentacion (RUT, biometria). Modulo: src/identity/ra.rs.
Administrador de Sistemas	Gestiona la infraestructura de servidores, redes y contenedores Docker.
Auditor Interno	Revisa registros de auditoria, verifica integridad de cadena de hash, ejecuta auditorias periodicas.
Custodios de Claves (minimo 3)	Participan en la ceremonia de claves M-de-N. Cada custodio posee un fragmento. Modulo: src/pki_ceremony.rs.

3.2. Segregacion de funciones

Se aplica el principio de segregacion de funciones (separation of duties) conforme a NCh-ISO 27002 control 6.1.2:

- Ningun individuo puede desempenar simultaneamente los roles de Administrador de CA y Auditor Interno.
- La ceremonia de generacion de claves requiere la presencia de al menos 3 custodios, 2 testigos y 1 notario publico.
- El acceso al HSM en produccion requiere autenticacion multi-factor (PIN del custodio + presencia fisica).

3.3. Comite de seguridad

Se constituye un Comite de Seguridad de la Informacion que sesiona trimestralmente para:

- Revisar incidentes de seguridad del periodo.
 - Evaluar la eficacia de los controles implementados.
 - Aprobar cambios al presente Plan de Seguridad.
 - Supervisar el cumplimiento del plan de continuidad del negocio.
-

4. Gestion de activos

4.1. Inventario de activos criticos

4.1.1. Activos de informacion

Activo	Clasificacion	Ubicacion	Responsable
Clave privada de CA raiz	Estrictamente confidencial	HSM offline (FIPS 140-2 L3)	Custodios de claves
Clave privada de CA intermedia	Estrictamente confidencial	HSM operacional (FIPS 140-2 L3)	Administrador de CA
Claves de firma FEA de suscriptores	Confidencial	HSM operacional	Suscriptor / Administrador de CA
Certificados de suscriptores	Publico	RocksDB + directorio LDAP	Administrador de Sistemas
Registros de auditoria (hash chain)	Confidencial	RocksDB con cifrado AES-256-GCM	Auditor Interno
Datos biometricos ISO 19794-2	Estrictamente confidencial	Almacenamiento cifrado at-rest	Oficial de Registro
Base de datos de identidades DID	Confidencial	RocksDB	Administrador de Sistemas

4.1.2. Activos de software

Componente	Modulo	Funcion
Nodo blockchain	src/main.rs, src/lib.rs	Nucleo del sistema; API HTTP Actix-Web
Modulo criptografico	crates/pqc_crypto_module/	Operaciones criptograficas FIPS; Ed25519, ML-DSA-65, RSA, SHA-256
Motor de firma	src/signature/	FES (Ed25519), FEA (ML-DSA-65 + biometria), CAdES, XAdES, PAdES
Gestion de identidad	src/identity/	DID, claves, HSM PKCS#11, firma, RA, ZKP
Sellado de tiempo	src/tsa/	TSA RFC 3161 con codificacion DER
Control de acceso	src/acl/	ACL permisivo/estricto via ACL_MODE
Auditoria	src/audit.rs, src/audit_retention.rs	Registro con hash chain, retencion 7 anos
PKI	src/pki_ceremony.rs, src/pki_lifecycle.rs, src/pki_policy.rs	Ceremonia M-de-N, ciclo de vida, politicas
Almacenamiento	src/storage/	RocksDB con cifrado at-rest AES-256-GCM
Red P2P	src/network/	TLS mutuo, gossip, propagacion de bloques
Consenso	src/consensus/	DAG + HotStuff BFT + DPoS
Forense	src/forensic.rs	Analisis forense digital

4.1.3. Activos fisicos

Activo	Cantidad minima	Ubicacion
HSM FIPS 140-2 Level 3	2 (primario + respaldo)	Datacenter Tier III, Chile
Servidores de nodo	3 (minimo para BFT)	Datacenter Tier III
Medios de respaldo cifrados	2 juegos	Datacenter + sitio alternativo
Tarjetas de operador HSM	Segun esquema M-de-N	Custodia individual

4.2. Clasificación de la información

Se adoptan cuatro niveles de clasificación conforme a NCh-ISO 27002:

1. **Estrictamente confidencial:** Claves privadas de CA, datos biométricos, credenciales HSM.
 2. **Confidencial:** Registros de auditoría, datos personales de suscriptores, configuraciones de seguridad.
 3. **Uso interno:** Documentación técnica, procedimientos operacionales, código fuente.
 4. **Público:** Certificados emitidos, CPS publicado, CRL, respuestas OCSP.
-

5. Seguridad del personal

5.1. Requisitos previos a la contratación

Todo el personal que opere en roles definidos en la sección 3.1 deberá:

- Presentar certificado de antecedentes vigente emitido por el Registro Civil e Identificación.
- Firmar acuerdo de confidencialidad y no divulgación.
- Firmar declaración de conflictos de interés.
- Acreditar competencia técnica pertinente al rol mediante título profesional o certificación reconocida.

5.2. Verificación de antecedentes

Para los roles de Administrador de CA y Custodios de Claves se requiere adicionalmente:

- Verificación de antecedentes comerciales (DICOM/Equifax).
- Verificación de antecedentes penales.
- Referencia de al menos dos empleadores anteriores.

5.3. Capacitación

El personal recibe capacitación obligatoria en:

Tema	Frecuencia	Dirigido a
Política de seguridad de la información	Anual	Todo el personal
Procedimiento de ceremonia de claves	Previo a cada ceremonia	Custodios, testigos, Administrador de CA
Respuesta a incidentes de seguridad	Semestral	Todo el personal técnico
Protección de datos personales	Anual	Oficial de Registro, Administrador de Sistemas

Tema	Frecuencia	Dirigido a
Actualizacion normativa (Ley 19.799, DS 181)	Anual	CISO, Administrador de CA, Auditor Interno

5.4. Desvinculacion

Al termino de la relacion laboral:

- Se revocan inmediatamente todas las credenciales de acceso (ACL, HSM, VPN, acceso fisico).
- Se recuperan tarjetas de operador HSM y cualquier medio fisico.
- Se ejecuta un traspaso documentado de funciones.
- El acuerdo de confidencialidad permanece vigente por 5 anos posteriores a la desvinculacion.

6. Seguridad fisica y ambiental

6.1. Perimetro de seguridad fisica

La infraestructura critica del PSC se aloja en un datacenter Tier III ubicado en territorio chileno, conforme al DS 181 articulo 15. El datacenter debe cumplir:

- Control de acceso biometrico y tarjeta de proximidad en todas las puertas.
- Circuito cerrado de television (CCTV) con grabacion continua y retencion minima de 90 dias.
- Registro de ingreso y salida de todo personal y visitantes.
- Deteccion y extincion automatica de incendios.
- Sistema de alimentacion ininterrumpida (UPS) con autonomia minima de 30 minutos.
- Grupo electrogeno con arranque automatico y autonomia minima de 24 horas.
- Climatizacion redundante N+1.

6.2. Sala de ceremonias

Para la ejecucion de ceremonias de claves (`src/pki_ceremony.rs`), se dispone de una sala con:

- Acceso restringido exclusivamente al personal autorizado para la ceremonia.
- CCTV con grabacion de la totalidad del procedimiento.
- Inhibicion de senales inalambricas durante la ceremonia.
- Registro notarial del procedimiento.

6.3. Proteccion del HSM

- El HSM se instala en rack cerrado con llave, dentro de la zona de maxima seguridad del datacenter.
- El acceso al rack requiere doble autorizacion (Administrador de CA + Oficial de Seguridad).
- Las tarjetas de operador se almacenan en caja fuerte con acceso M-de-N.

- El HSM de respaldo se ubica en un sitio geograficamente separado.

Referencia detallada: docs/compliance/PHYSICAL-SECURITY.md.

7. Gestion de comunicaciones y operaciones

7.1. Seguridad en las comunicaciones

7.1.1. TLS y cifrado en transito

Todas las comunicaciones se protegen mediante TLS 1.3 con las siguientes configuraciones:

Control	Implementacion
TLS mutuo (mTLS)	Obligatorio para comunicacion entre nodos P2P (src/network/mod.rs)
Certificate pinning	Implementado para conexiones criticas CA-a-nodo
OCSP stapling	Habilitado en el servidor HTTP; respuestas OCSP pre-cargadas
Suites criptograficas	TLS_AES_256_GCM_SHA384, TLS_CHACHA20_POLY1305_SHA256
Certificados de servidor	Emitidos por la CA intermedia del PSC

En entorno de produccion (RUST_BC_ENV=production), las variables TLS_CERT_PATH y TLS_KEY_PATH son obligatorias. El sistema rechaza el arranque sin ellas.

7.1.2. Red P2P

La red peer-to-peer (src/network/) utiliza:

- Protocolo TCP con TLS mutuo para todas las conexiones entre nodos.
- Push-gossip para propagacion de bloques (src/network/gossip.rs).
- Mensajeria tipada: SubmitTransaction, OrderedBlock, StateRequest, StateResponse.
- Identificacion de nodos mediante DID: did:goya:{pubkey_hex[..16]}.

7.1.3. API HTTP

La API expuesta en /api/v1 implementa:

Control	Configuracion
Rate limiting	Configurable via RATE_LIMIT_RPS, RATE_LIMIT_RPM, RATE_LIMIT_RPH
CORS	Origenes permitidos via CORS_ALLOWED_ORIGINS

Control	Configuracion
Timeout	HTTP_REQUEST_TIMEOUT_SECS (configurable)
Trazabilidad	Trace ID en cada respuesta (ApiResponse<T>)
Envelope estandar	Todas las respuestas envueltas en ApiResponse<T> con trace ID

7.2. Gestion de operaciones

7.2.1. Despliegue

Aspecto	Implementacion
Contenerizacion	Docker multi-nodo (docker compose)
Infraestructura en la nube	Fly.io para entornos no productivos
Automatizacion	Scripts de despliegue (scripts/ sandbox.sh, scripts/bcctl.sh)
E2E	71 aserciones automatizadas (scripts/e2e-test.sh)
Pre-commit	cargo fmt --check, cargo clippy -- -D warnings, cargo test --lib

7.2.2. Gestion de cambios

Todo cambio en el codigo fuente pasa por:

1. Revision de codigo por pares.
2. Suite de pruebas automatizadas (2.400+ tests).
3. Validacion de frontera criptografica (cargo test --test crypto_boundary).
4. Analisis estatico con Clippy (warnings tratados como errores).
5. Formateo obligatorio con cargo fmt.

7.2.3. Respaldo y recuperacion

- Respaldo diario de RocksDB con cifrado.
- Respaldo de configuracion HSM (HsmSigningProvider::backup_info()).
- La variable VAULT_RECOVERY_SECRET almacena el secreto de recuperacion del vault.
- Procedimiento de recuperacion documentado en docs/compliance/BUSINESS-CONTINUITY-DR.md.

8. Control de acceso

8.1. Politica de control de acceso

El sistema implementa control de acceso basado en dos modos, configurables mediante la variable de entorno `ACL_MODE`:

Modo	Comportamiento	Uso
permissive	Permite operaciones por defecto; registra violaciones	Desarrollo y pruebas
strict	Deniega operaciones no expresamente autorizadas	Produccion (obligatorio)

La implementacion se encuentra en `src/acl/`:

- `src/acl/mod.rs` — Logica central de ACL.
- `src/acl/checker.rs` — Verificacion de permisos.
- `src/acl/provider.rs` — Proveedor de politicas.
- `src/acl/resources.rs` — Definicion de recursos protegidos.

La funcion `enforce_acl` se invoca en cada handler de la API para verificar autorizacion.

8.2. Autenticacion

Mecanismo	Aplicacion
Firma digital DID	Autenticacion de nodos y suscriptores. Derivacion canonica: <code>identity::did::did_from_pubkey_hex()</code> .
PKCS#11 PIN + tarjeta	Acceso operacional al HSM (<code>src/identity/hsm.rs</code>)
mTLS con certificado de cliente	Comunicacion inter-nodo
Credenciales de operador	Acceso a la consola de administracion

8.3. Gestion de identidades

La plataforma utiliza identificadores descentralizados (DID) con el metodo `did:goya`:

- Formato: `did:goya:{pubkey_hex[..16]}`.
- Derivacion canonica via `identity::did::did_from_pubkey_hex()` — toda generacion de DID debe usar esta funcion.
- Registro y revocacion auditados (`AuditAction::DidRegistered`, `AuditAction::DidRevoked`).

8.4. Control de acceso al HSM

El acceso al HSM se controla mediante:

- Configuración via variables de entorno: `HSM_PKCS11_LIB`, `HSM_SLOT_ID`, `HSM_PIN`, `HSM_KEY_LABEL`.
 - Autenticación mediante `HsmConfig::from_env()` (`src/identity/hsm.rs`).
 - Operaciones de firma y verificación canalizadas exclusivamente a través de `HsmSigningProvider`.
 - Proveedor simulado `SimulatedHsmProvider` disponible únicamente para pruebas; prohibido en producción.
-

9. Controles criptograficos

9.1. Política criptografica

Toda operación criptográfica se canaliza exclusivamente a través del módulo `crates/pqc_crypto_module/`, conforme al principio de frontera criptográfica. Queda expresamente prohibido el uso directo de las bibliotecas `sha2`, `ed25519_dalek` u otras en el código fuente de `src/`. Esta restricción se verifica automáticamente mediante `cargo test --test crypto_boundary`.

9.2. Algoritmos aprobados

Algoritmo	Uso	Modulo	Tamaño de firma
Ed25519 (RFC 8032)	Firma electrónica simple (FES)	<code>crates/pqc_crypto_module/src/legacy.rs</code>	64 bytes
ML-DSA-65 (FIPS 204)	Firma electrónica avanzada (FEA) — post-cuántico	<code>crates/pqc_crypto_module/src/mldsa.rs</code>	3.309 bytes
RSA-2048/4096	Interoperabilidad con sistemas externos	<code>crates/pqc_crypto_module/</code>	Variable
SHA-256 (FIPS 180-4)	Hashing para cadena de auditoría, Merkle proofs	<code>crates/pqc_crypto_module/src/ hashing.rs</code>	32 bytes
AES-256-GCM	Cifrado at-rest de RocksDB	Configuración de almacenamiento	N/A
ML-KEM (FIPS 203)	Encapsulación de claves post-cuántica	<code>crates/pqc_crypto_module/src/mlkem.rs</code>	Variable

Las firmas se almacenan como Vec<u8> (no [u8; 64]) para soportar tanto Ed25519 (64 bytes) como ML-DSA-65 (3.309 bytes). La serializacion se realiza en hexadecimal via el modulo vec_hex.

Todo struct firmado incluye el campo signature_algorithm: SigningAlgorithm con #[serde(default)] para garantizar la trazabilidad del algoritmo utilizado.

9.3. Formatos de firma electronica

Formato	Norma	Modulo
CAdES-BES/T (DER)	ETSI EN 319 122	src/signature/ cades.rs, src/ signature/ cades_der.rs
XAdES	ETSI EN 319 132	src/signature/ xades.rs
PAdES	ETSI EN 319 142	src/signature/ pades.rs, src/ signature/ pades_der.rs

El modulo src/signature/verify.rs implementa el despachador unificado verify_signature y la funcion validate_fes_fea para validar el nivel de firma (simple vs. avanzada).

9.4. Sellado de tiempo

La Autoridad de Sellado de Tiempo implementa RFC 3161 con codificacion DER:

- Modulo: src/tsa/mod.rs y src/tsa/rfc3161_der.rs.
- NTP enforcement obligatorio para garantizar precision temporal.
- Los sellos de tiempo se incluyen como atributos firmados en CAdES-T.

9.5. Autotests criptograficos

El modulo criptografico ejecuta autotests al inicio (power-on self-tests) conforme a FIPS 140-2:

- Modulo: crates/pqc_crypto_module/src/self_tests.rs.
- Modo aprobado: crates/pqc_crypto_module/src/approved_mode.rs.
- Generador de numeros aleatorios: crates/pqc_crypto_module/src/rng.rs.
- Vectores de prueba CAVP NIST para SHA-256 y Ed25519 (RFC 8032).

9.6. Gestion del ciclo de vida de claves

Etapas	Control	Modulo
Generacion		src/pki_ceremony.rs

Etapas	Control	Modulo
	Ceremonia M-de-N con custodios, testigos y notario	
Almacenamiento	HSM FIPS 140-2 Level 3 via PKCS#11	src/identity/hsm.rs
Distribucion	Certificados X.509 emitidos por CA intermedia	src/pki_lifecycle.rs
Uso	Firma delegada al HSM; clave privada nunca exportada	src/identity/signing.rs
Rotacion	Politica de vigencia definida en CP/CPS	src/pki_policy.rs
Revocacion	CRL (RFC 5280) y OCSP (RFC 6960)	src/pki_lifecycle.rs
Destruccion	Procedimiento de destruccion en HSM con acta notarial	src/pki_ceremony.rs

La politica de claves (src/pki_policy.rs) define:

- Vigencia maxima de certificados de suscriptor.
- Vigencia de certificados de CA intermedia y raiz.
- Algoritmos permitidos por nivel de firma.
- Restricciones de uso de claves (key usage, extended key usage).

9.7. Firma dual y transicion post-cuantica

El modulo src/identity/dual_signing.rs implementa firma dual Ed25519 + ML-DSA-65 para permitir una transicion gradual hacia criptografia post-cuantica, conforme a las recomendaciones del NIST para migracion PQC.

La politica PQC se gestiona en src/identity/pqc_policy.rs.

Referencia detallada: docs/compliance/PQC-ENTERPRISE.md.

10. Gestion de incidentes

10.1. Registro de auditoria

El sistema de auditoria (src/audit.rs) implementa:

- **Cadena de hash:** Cada entrada (AuditEntry) contiene previous_hash y entry_hash, formando una cadena inmutable verificable.
- **Verificacion de integridad:** verify_audit_chain() valida la integridad de toda la cadena.

- **Sellado:** `AuditEntry::seal()` calcula el hash de la entrada enlazandola con la anterior.
- **Verificacion individual:** `AuditEntry::verify()` comprueba la consistencia de una entrada.

10.1.1. Eventos auditados

El enum `AuditAction` registra, entre otros:

- `HttpRequest` — Toda solicitud HTTP recibida.
- `BlockMined` — Bloque comprometido.
- `WalletCreated` — Creacion de billetera.
- `TokenTransfer`, `TokenStaked`, `TokenUnstaked` — Operaciones con tokens.
- `ChaincodeInstalled`, `ChaincodeUpgraded` — Cambios en smart contracts.
- `DidRegistered`, `DidRevoked` — Operaciones de identidad.

10.1.2. Campos de cada registro

Cada `AuditEntry` contiene:

Campo	Descripcion
<code>timestamp</code>	Marca temporal ISO 8601
<code>action</code>	Tipo de evento (<code>AuditAction</code>)
<code>method</code>	Metodo HTTP
<code>path</code>	Ruta del endpoint
<code>org_id</code>	Identificador de la organizacion
<code>source_ip</code>	Direccion IP de origen
<code>status_code</code>	Codigo de respuesta HTTP
<code>trace_id</code>	Identificador unico de trazabilidad
<code>duration_ms</code>	Duracion de la operacion en milisegundos
<code>metadata</code>	Metadatos adicionales (opcional)
<code>previous_hash</code>	Hash de la entrada anterior (cadena)
<code>entry_hash</code>	Hash de la entrada actual

10.2. Retencion de registros

Conforme al DS 181 y la Ley 19.799, los registros de auditoria se conservan por un minimo de 7 anos:

- Modulo: `src/audit_retention.rs`.
- Constante: `DEFAULT_RETENTION_SECS = 7 * 365 * 24 * 3600` (220.752.000 segundos).
- La politica `AuditRetentionPolicy` define:
 - `min_retention_secs`: Periodo minimo de retencion (por defecto 7 anos). Las entradas dentro de este periodo jamas se purgan.
 - `max_retention_secs`: Periodo maximo tras el cual las entradas son elegibles para archivado. 0 = retencion indefinida.
 - `auto_purge_enabled`: Purgado automatico (deshabilitado por defecto).

- Funciones de filtrado: `is_retained()`, `is_purgeable()`, `filter_retained()`, `count_purgeable()`.

10.3. Analisis forense

El modulo `src/forensic.rs` provee capacidades de analisis forense digital para la investigacion de incidentes de seguridad, incluyendo:

- Recoleccion y preservacion de evidencia digital.
- Analisis de cadena de custodia.
- Generacion de informes forenses.

Referencia adicional: `src/forensic_pentest.rs` para pruebas de penetracion.

10.4. Procedimiento de respuesta a incidentes

El procedimiento detallado se encuentra en `docs/compliance/INCIDENT-RESPONSE-PLAN.md`. En sintesis:

1. **Deteccion:** Monitoreo continuo de logs, alertas automaticas, verificacion periodica de cadena de hash.
2. **Clasificacion:** Categorizacion por severidad (critica, alta, media, baja).
3. **Contencion:** Aislamiento del sistema afectado, revocacion de credenciales comprometidas.
4. **Erradicacion:** Eliminacion de la causa raiz, parcheo de vulnerabilidades.
5. **Recuperacion:** Restauracion desde respaldos verificados, re-emision de certificados si corresponde.
6. **Leccion aprendida:** Informe post-incidente, actualizacion de controles.

10.5. Notificacion

Conforme al articulo 16 del DS 181, el PSC debe notificar a la Subsecretaria de Economia dentro de 24 horas cualquier compromiso de:

- Clave privada de la CA raiz o intermedia.
- Integridad de la cadena de auditoria.
- Disponibilidad del servicio de validacion (OCSP/CRL) por mas de 4 horas.

Adicionalmente, se notifica a los suscriptores afectados dentro de 48 horas.

11. Continuidad del negocio

11.1. Plan de continuidad

El plan detallado se encuentra en `docs/compliance/BUSINESS-CONTINUITY-DR.md`. Los elementos clave incluyen:

11.1.1. Objetivos de recuperacion

Metrica	Objetivo
RTO (Recovery Time Objective)	4 horas para servicios de validacion (OCSP/CRL)
RPO (Recovery Point Objective)	1 hora para registros de auditoria
Disponibilidad anual	99.5% para servicios de certificacion

11.1.2. Arquitectura de alta disponibilidad

- Consenso BFT (src/consensus/bft/) con tolerancia a fallas bizantinas: el sistema tolera hasta f nodos maliciosos con $3f+1$ nodos totales.
- Despliegue multi-nodo via Docker Compose.
- RocksDB con replicacion entre nodos.

11.1.3. Respaldo y recuperacion de claves

- Respaldo cifrado del HSM en sitio alterno geograficamente separado.
- Procedimiento de recuperacion de claves documentado y probado semestralmente.
- Secreto de recuperacion almacenado via VAULT_RECOVERY_SECRET.

11.1.4. Servicios de validacion

- OCSP responder con respuestas pre-firmadas para garantizar disponibilidad durante contingencia.
- CRL publicada cada 24 horas en condiciones normales; publicacion de emergencia en caso de revocacion de CA.

11.2. Pruebas del plan

Se realizan pruebas del plan de continuidad con la siguiente periodicidad:

Tipo de prueba	Frecuencia
Prueba de escritorio (table-top)	Trimestral
Prueba de respaldo y restauracion	Mensual
Prueba de failover completo	Semestral
Simulacro de compromiso de clave CA	Anual

12. Cumplimiento

12.1. Cumplimiento normativo

12.1.1. Ley 19.799

El PSC cumple con los requisitos de la Ley 19.799 mediante:

Requisito	Implementacion
Art. 2 — Firma electronica simple	FES via Ed25519 (src/signature/mod.rs)
Art. 2 — Firma electronica avanzada	FEA via ML-DSA-65 + biometria ISO 19794-2 (src/signature/mod.rs, src/signature/iso19794.rs)
Art. 12 — Obligaciones del PSC	CPS publicado, auditoria, revocacion, sellado de tiempo
Art. 14 — Seguro de responsabilidad civil	Contratado conforme a PSC-CERTIFICATION-ROADMAP fase 1.3

12.1.2. Decreto Supremo N.o 181

Articulo	Requisito	Control
Art. 13	Infraestructura tecnica adecuada	HSM FIPS 140-2 L3, datacenter Tier III
Art. 14	Personal cualificado	Seccion 5 del presente plan
Art. 15	Seguridad fisica	Seccion 6; docs/compliance/PHYSICAL-SECURITY.md
Art. 16	Notificacion de incidentes	Seccion 10.5
Art. 17	Registros de operacion	Auditoria con hash chain, retencion 7 anos
Art. 18	Plan de contingencia	Seccion 11; docs/compliance/BUSINESS-CONTINUITY-DR.md

12.1.3. FIPS 140-2

El modulo criptografico (crates/pqc_crypto_module/) se disena conforme a FIPS 140-2:

- Autotests al inicio (self_tests.rs).
- Modo aprobado (approved_mode.rs).
- Generador de numeros aleatorios validado (rng.rs).
- Frontera criptografica verificada por prueba automatizada.

12.2. Auditorias

Tipo	Frecuencia	Alcance
Auditoria interna de seguridad	Semestral	Todos los controles del presente plan
Auditoria externa de cumplimiento	Anual	Conformidad con DS 181 y NCh-ISO 27001
Prueba de penetracion	Anual	Infraestructura y aplicacion; src/forensic_pentest.rs
Verificacion de integridad de logs	Diaria (automatizada)	verify_audit_chain()
Revision de codigo de seguridad	Por cada release	Analisis estatico (Clippy) + revision de pares

12.3. Mejora continua

El presente Plan de Seguridad se revisa y actualiza:

- Al menos una vez al año.
- Ante cualquier incidente de seguridad significativo.
- Ante cambios normativos relevantes.
- Ante cambios sustanciales en la arquitectura del sistema.

Cada revision se documenta con numero de version, fecha y aprobacion del Comité de Seguridad.

Anexo A — Mapa de controles NCh-ISO 27001:2013

Dominio ISO 27001	Seccion del plan
A.5 Políticas de seguridad	Secciones 1, 2
A.6 Organizacion de la seguridad	Seccion 3
A.7 Seguridad del recurso humano	Seccion 5
A.8 Gestion de activos	Seccion 4
A.9 Control de acceso	Seccion 8
A.10 Criptografia	Seccion 9
A.11 Seguridad fisica y ambiental	Seccion 6
A.12 Seguridad de las operaciones	Seccion 7
A.13 Seguridad de las comunicaciones	Seccion 7.1
A.14 Adquisicion, desarrollo y mantenimiento	Seccion 7.2.2
A.16 Gestion de incidentes	Seccion 10
A.17 Continuidad del negocio	Seccion 11

Dominio ISO 27001	Seccion del plan
A.18 Cumplimiento	Seccion 12

Anexo B — Variables de entorno de seguridad

Variable	Funcion	Valor en produccion
ACL_MODE	Modo de control de acceso	strict (obligatorio)
RUST_BC_ENV	Entorno de ejecucion	production
TLS_CERT_PATH	Ruta al certificado TLS del servidor	Requerido
TLS_KEY_PATH	Ruta a la clave privada TLS del servidor	Requerido
STORAGE_BACKEND	Motor de almacenamiento	rocksdb
SIGNING_ALGORITHM	Algoritmo de firma por defecto	ml-dsa-65 (FEA)
LOG_FORMAT	Formato de logs	json
RATE_LIMIT_RPS	Limite de solicitudes por segundo	Segun capacidad
RATE_LIMIT_RPM	Limite de solicitudes por minuto	Segun capacidad
RATE_LIMIT_RPH	Limite de solicitudes por hora	Segun capacidad
VAULT_RECOVERY_SECRET	Secreto de recuperacion del vault	Almacenado en HSM
NETWORK_ID	Identificador de red	Unico por entorno

Anexo C — Glosario

Termino	Definicion
CA	Autoridad de Certificacion (Certification Authority)
CAdES	CMS Advanced Electronic Signatures
CP	Politica de Certificacion (Certificate Policy)
CPS	Declaracion de Practicas de Certificacion (Certification Practice Statement)
CRL	Lista de Certificados Revocados (Certificate Revocation List)
DID	Identificador Descentralizado (Decentralized Identifier)

Termino	Definicion
DPoS	Delegated Proof of Stake
FEA	Firma Electronica Avanzada (Ley 19.799 Art. 2)
FES	Firma Electronica Simple (Ley 19.799 Art. 2)
HSM	Modulo de Seguridad de Hardware (Hardware Security Module)
ML-DSA	Module-Lattice-Based Digital Signature Algorithm (FIPS 204)
ML-KEM	Module-Lattice-Based Key Encapsulation Mechanism (FIPS 203)
mTLS	TLS mutuo (Mutual TLS)
OCSP	Online Certificate Status Protocol (RFC 6960)
PAdES	PDF Advanced Electronic Signatures
PKCS#11	Interfaz criptografica para tokens de hardware
PQC	Criptografia Post-Cuantica (Post-Quantum Cryptography)
PSC	Prestador de Servicios de Certificacion
RA	Autoridad de Registro (Registration Authority)
TSA	Autoridad de Sellado de Tiempo (Time Stamping Authority)
XAdES	XML Advanced Electronic Signatures
ZKP	Prueba de Conocimiento Cero (Zero-Knowledge Proof)

Fin del documento.